

Low-Level Protocol Exploitation and Physical-Layer Defenses for NFC Smart Lock Systems

NUSSoC 2026 Summer Workshop DADA Project Report

Xinjie Liu
Chu Kou Chen College, Zhejiang
University
Hangzhou, China
kawaiiishinsuguru@gmail.com

Yulin Li
College of Computer Science and
Technology, Zhejiang University
Hangzhou, China
LeenSed@163.com

Chengfeier Pei
School of Integrated Circuits,
Shanghai Jiao Tong University
Shanghai, China
faye-official@sjtu.edu.cn

Canyu Liu
Chu Kou Chen College, Zhejiang
University
Hangzhou, China
liucanyu0411@gmail.com

Peize Yang
School of Integrated Circuits,
Shanghai Jiao Tong University
Shanghai, China
legacy1083@sjtu.edu.cn

Abstract

Near Field Communication (NFC) technology has become ubiquitous in information exchange and access control, such as contactless payments and smart locks. As sensitive applications multiply, these systems increasingly attract sophisticated adversarial exploits, demanding a broader consideration of potential threat vectors. In this project, we focus on two complementary aspects of NFC smart lock security. On the attack side, we employ a Proxmark3 platform to demonstrate full credential recovery from MIFARE Classic 1K cards by exploiting weaknesses in the proprietary Crypto-1 cipher, and subsequently produce functional clones using rewritable Magic Cards. On the defense side, we use a HackRF One Software Defined Radio to capture the raw 13.56 MHz physical-layer signals during card-reader interactions and extract radio-frequency fingerprints—such as carrier frequency offset, modulation transient shape, and RSSI profile—that are unique to each physical card and inherently non-transferable through cloning. This dual approach establishes both an end-to-end attack demonstration and a hardware-grounded countermeasure that operates below the protocol layer.

Keywords

NFC Security, MIFARE Classic, Crypto-1, Proxmark3, SDR Fingerprinting

1 Introduction

1.1 NFC Technology

Near Field Communication (NFC) is a short-range wireless technology operating at 13.56 MHz within the High Frequency (HF) band of the RFID spectrum. As a subset of Radio Frequency Identification (RFID) standardized under ISO/IEC 14443 [2], NFC enables bidirectional data exchange between an active initiator device and a passive or active target within a typical range of 4–10 cm.

Unlike far-field RFID systems that rely on electromagnetic wave propagation, NFC communication is strictly based on inductive coupling between two coil antennas. The initiator (e.g., a smart lock reader) generates an alternating magnetic field, which induces a current in the target’s coil (e.g., a keycard or smartphone), thereby

powering the target. The target responds by modulating its coil impedance, a technique known as load modulation, which the initiator detects as amplitude variations on the carrier. Two encoding schemes are defined for proximity cards under ISO/IEC 14443 Type A: Modified Miller encoding with 100% amplitude shift keying (ASK) for reader-to-card communication, and Manchester encoding with subcarrier load modulation for card-to-reader responses, typically at a data rate of 106 kbps [3].

The widespread adoption of NFC in access control, contactless payment, and identity verification has made these systems a high-value target for adversaries [4]. Although the short operational range inherently limits remote eavesdropping, the physical layer remains susceptible to close-range sniffing and replay attacks. This vulnerability forms the primary motivation for hardware-defined defense paradigms explored in this work.

1.2 Security Threats in NFC Systems

Despite the short communication range, NFC has accumulated an increasingly diverse threat landscape over the past two decades. Early analyses by Haselsteiner and Breitfuß [5] identified canonical attack categories—eavesdropping, data manipulation, and relay—that remain relevant but have been significantly amplified by cheaper hardware and open-source toolchains. Figure 1 illustrates the growth in documented NFC and high-frequency RFID exploits between 2006 and 2024, compiled from peer-reviewed publications and CVE entries. The number of publicly reported attack techniques has roughly tripled over this period, with a noticeable acceleration after 2018 driven by the availability of low-cost SDR platforms such as the HackRF One and the Proxmark3 ecosystem [1].

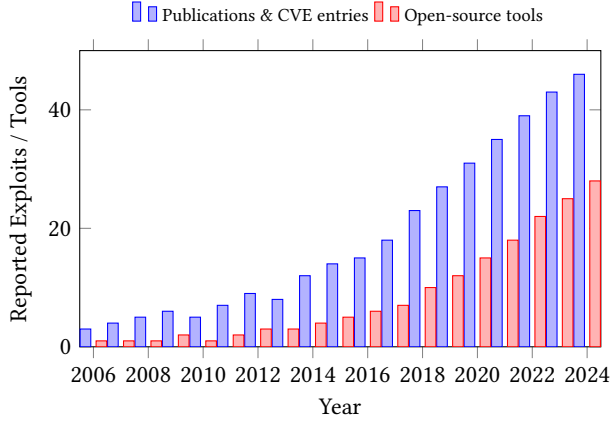


Figure 1: Growth of documented NFC/RFID exploits and open-source attack tools (2006–2024). Data from peer-reviewed literature and the CVE database.

Beyond raw quantity, the diversity of attack vectors has expanded considerably, as summarized in Figure 2. Early threats were largely limited to passive eavesdropping and relay; modern adversaries now employ card emulation, side-channel analysis, algebraic key-recovery, and multi-layer protocol exploitation [4]. The emergence of the “Chinese Magic Card” (rewritable Block 0 MIFARE chips) has further commoditised cloning attacks, enabling an attacker to duplicate both the UID and the sector payload without specialist fabrication equipment.

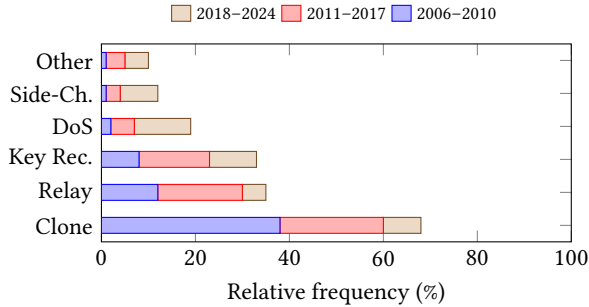


Figure 2: Evolution of NFC attack-vector distribution across three time periods. Cloning and relay remain dominant, but key-recovery and denial-of-service attacks have grown notably since 2018.

Beyond raw quantity, the diversity of attack vectors has expanded considerably, as summarized in Figure 2. Early threats were largely limited to passive eavesdropping and relay; modern adversaries now employ card emulation, side-channel analysis, algebraic key-recovery, and multi-layer protocol exploitation [4]. The emergence of the “Chinese Magic Card” (rewritable Block 0 MIFARE chips) has further commoditised cloning attacks, enabling an attacker to duplicate both the UID and the sector payload without specialist fabrication equipment.

The combination of a growing attack surface and commodity-grade offensive hardware has eroded the implicit “proximity-equals-security” assumption on which most NFC access-control deployments were originally designed. This motivates the need for defense mechanisms that operate below the protocol layer, at the physical radio interface, where adversarial presence can be detected from signal-level anomalies rather than from credential content alone.

1.3 Contributions and Paper Organization

In this work, we investigate NFC smart lock security from both adversarial and defensive perspectives, using openly available hardware and software toolchains. Our principal contributions are as follows:

- (1) **End-to-end attack demonstration.** We replicate a complete credential-recovery and card-cloning attack against MIFARE Classic 1K access cards, leveraging a Proxmark3 platform to exploit the well-documented weaknesses of the Crypto-1 stream cipher. The attack chain covers nonce collection, key recovery, sector dump, and production of a functional clone using rewritable Magic Cards.
- (2) **Physical-layer anti-cloning defense.** We propose a defense strategy that operates at the 13.56 MHz RF physical layer, independent of the upper-layer protocol. By capturing reader-card interactions with a HackRF One SDR and analyzing per-card signal fingerprints, we create a verification pipeline that can distinguish a genuine card from an identical clone.
- (3) **Integrated prototype system.** We build and release a cross-platform smart lock implementation that combines standard PCSC card I/O with the SDR-based fingerprint verification, serving as a reproducible testbed for both attack and defense evaluation.

The remainder of this paper is organized as follows. Section 2 provides background on MIFARE Classic and the Crypto-1 cipher. Section 3 describes the smart-lock credential model and a methodology for evaluating it. Section 4 presents the Proxmark3 command workflow, repository evidence, and a theoretical end-to-end validation method. Section 5 presents the physical-layer fingerprinting defense. Section 6 discusses limitations and future work, and Section 7 concludes.

2 MIFARE Classic and Crypto-1

2.1 MIFARE Classic Memory Architecture

The MIFARE Classic 1K is one of the most widely deployed contactless smart cards globally, consisting of a chip, antenna, and card body as illustrated in Figure 3.

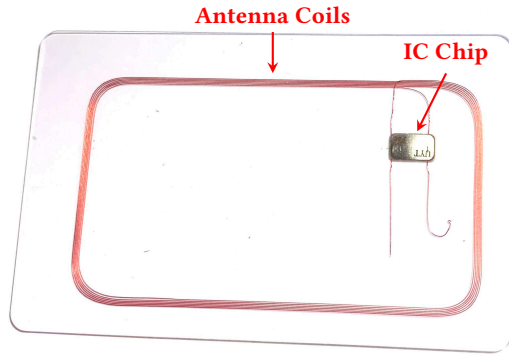


Figure 3: MIFARE Classic 1K

Operating at 13.56 MHz, it complies with parts 1–3 of the ISO/IEC 14443 Type A standard but diverges at the application layer by employing a proprietary protocol and cryptographic algorithm for access control [3]. The 1K variant features 1024 bytes of EEPROM, which is partitioned into 16 discrete sectors (numbered 0 to 15), as illustrated in Figure 4.

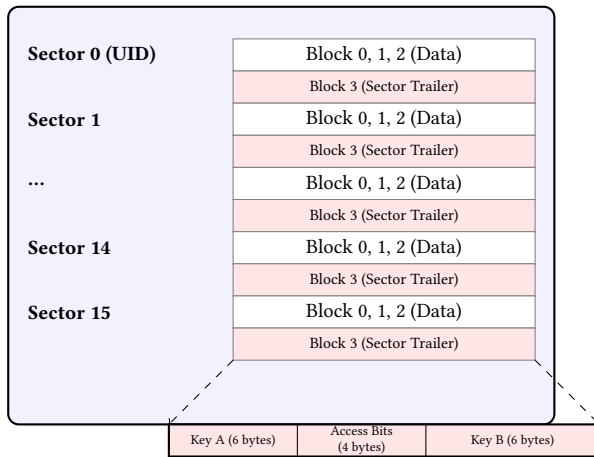


Figure 4: MIFARE Classic 1K memory organization and Sector Trailer structure.

Each sector consists of four 16-byte blocks. The first three blocks (Blocks 0–2) are allocated for user data storage. A notable exception is Block 0 of Sector 0, which is programmed during silicon manufacturing and contains the 4-byte or 7-byte Unique Identifier (UID) alongside vendor data. By design, this block is permanently write-protected on authentic tags. The final block of every sector, known as the Sector Trailer (Block 3), dictates the access control policies for that specific sector. It holds two 48-bit authentication keys (Key A and Key B) separated by four bytes of access conditions. These conditions define the read and write permissions for the data blocks and the sector trailer itself, dependent on which key is successfully authenticated.

2.2 The Crypto-1 Stream Cipher

To protect data transmission and enforce sector-level access control, NXP Semiconductors implemented Crypto-1, a proprietary stream cipher. The algorithm’s design was kept secret under the premise of security through obscurity until it was successfully reverse-engineered by Garcia et al. in 2008 through microscopic silicon analysis [6].

Crypto-1 utilizes a 48-bit Linear Feedback Shift Register (LFSR) combined with a multi-layered non-linear boolean filter function $f(x)$ (Figure 5). The LFSR state is updated at each clock cycle based on a primitive feedback polynomial over GF(2). The generated keystream is subsequently XORed with the plaintext to produce ciphertext during reader-card over-the-air communication.

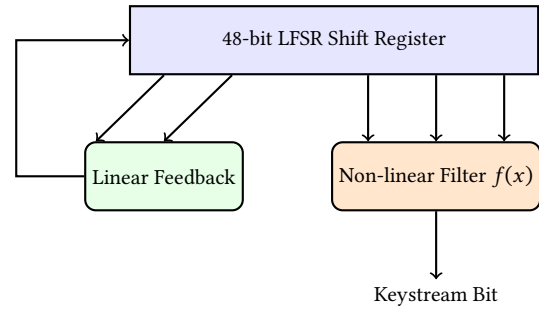


Figure 5: High-level architecture of the Crypto-1 stream cipher.

The sector authentication process relies on a three-pass mutual authentication protocol:

- (1) **Challenge:** The reader requests authentication for a specific sector block, and the card responds with a 32-bit random nonce (n_T).
- (2) **Response & Reader Nonce:** The reader responds with its own 32-bit nonce (n_R) and the encrypted answer to the card’s challenge, computed using the shared 48-bit sector key and the initial LFSR state.
- (3) **Card Verification:** If the reader’s response is correct, the card replies with the encrypted answer to the reader’s challenge, concluding the cryptographic handshake.

Despite its efficiency in resource-constrained environments, Crypto-1 exhibits several critical cryptographic flaws. The 48-bit key space is susceptible to brute-force attacks on modern hardware. More importantly, the reliance on a predictable pseudo-random number generator (PRNG) for generating n_T and the malleability of the parity bits in the ISO 14443-A framing allow attackers to deduce the internal LFSR state. Section 4 examines how these weaknesses can be exercised with commodity research hardware.

3 Smart-Lock Credential Model and Evaluation Method

3.1 Implemented Reader and Host Components

The README in the lock/ directory specifies an ACR122U or compatible 13.56 MHz PC/SC reader, MIFARE Classic 1K cards, and a

host computer. Running make in that directory builds lock, which continuously waits for a card and makes the access decision, and lock_admin, which writes the project credential format to a card.

The main loop in lock/src/main.c selects a PC/SC reader, waits for card insertion, connects using the active T=0 or T=1 transport, displays the UID, and calls auth_verify_card. A successful return invokes the access-granted hardware response; every failure invokes the access-denied response. The card is then disconnected before the next polling cycle.

3.2 Credential Provisioning and Memory Layout

The constants and structures in pcsc_common.h place the credential in Sector 1. Table 1 maps each block to the bytes written by lock_admin and the checks performed by lock.

Table 1: Sector 1 credential layout implemented in lock/.

Block	Stored fields	Runtime use
4	LOCK (4 B), card serial (4 B), access level (2 B), reserved (6 B)	Marker and UID comparison; access level is printed.
5	Random credential key (8 B), reserved (8 B)	First eight bytes are compared with the host whitelist.
6	Issue date (4 B), expiry date (4 B), reserved (8 B)	Date-format and expiry checks.
7	Key A (6 B), access bits (4 B), Key B (6 B)	Sector trailer; rewritten only when explicitly requested.

The administration program reads the current four-byte UID, writes it with the LOCK marker and access level to Block 4, generates eight random bytes for Block 5, and writes the issue and expiry dates to Block 6. The trailer is intentionally skipped unless --format-trailer is supplied, because an incorrect key or access-bit configuration can make the sector inaccessible. The immediate verification function in the administration program reads Block 4 and checks the marker.

3.3 Runtime Authentication Sequence

The runtime decision is fail-closed and proceeds in a fixed order:

- (1) The whitelist file is parsed as eight-byte hexadecimal values. Missing, malformed, or empty whitelist data causes a configuration failure.
- (2) Key A is loaded into the PC/SC reader and used to authenticate Block 4, thereby authenticating Sector 1.
- (3) Block 4 is read. The program checks the LOCK marker, obtains the PICC UID, and compares its first four bytes with the stored card serial.
- (4) Block 5 is read. Its first eight bytes must match one of the whitelist entries.
- (5) Block 6 is read. The issue date must have a valid format and the expiry date must not be in the past.
- (6) Only after the preceding checks does the function return AUTH_SUCCESS.

The access-level field is displayed but is not used as an authorization condition in the current decision function. Consequently, the enforced conditions are possession of the Sector 1 Key A, a matching marker and UID, a whitelisted credential key, and valid dates.

3.4 Theoretical Evaluation Method

A controlled evaluation of this credential model can use four inputs: a correctly provisioned card, an emulator loaded with the same logical image, a rewritable card containing the image, and an unrelated control card. For each presentation, the evaluator can record the return value at each decision boundary: sector authentication, marker verification, UID comparison, whitelist membership, date validation, and final grant or denial.

Logical equivalence can be measured independently of the door decision. A MIFARE Classic 1K image contains 64 blocks and 1024 bytes. A source image and a reproduced image can therefore be compared block by block, with sector trailers examined separately because access conditions may affect their readable representation. Repeating the acquisition can distinguish a stable mismatch from a transient communication failure. These procedures define an evaluation method; they do not by themselves constitute an experimental result.

From the code path, a logical reproduction would need to preserve the UID observed by the reader, the Key A required for Sector 1 authentication, and the contents of Blocks 4–6. This is a code-derived condition rather than a claim that a particular reproduced card has passed the lock.

4 Proxmark3 Credential Recovery and Card Reproduction

4.1 Cryptanalytic Basis

Crypto-1 uses a 48-bit internal state. MIFARE Classic applies it in a proprietary mutual authentication protocol. Published analyses show that weaknesses in the cipher, initialization, and nonce generation can permit key recovery and decryption without treating Crypto-1 as an ideal exhaustive-search problem [4, 6]. MIFARE Classic protects sectors with independent Key A and Key B values. Once one valid key is available, nested-family techniques can use authenticated exchanges as a starting point for recovering a target sector key. The hardnested variant implemented by Proxmark3 is intended for cards for which the simpler nested assumptions are hardened.

The command recorded in the repository selects Block 24 with Key A as the known source and Block 4 Key A as the target. Since MIFARE Classic 1K sectors contain four blocks, Block 24 is the first block of Sector 6 and Block 4 is the first block of Sector 1. The command-line mapping therefore expresses a cross-sector recovery attempt from a known Sector 6 credential to the Sector 1 credential used by the smart-lock format.

4.2 Repository Command Workflow

The Chinese-language instruction file under rrg_other/ records the command families in Table 2. Actual key values and card identifiers are omitted here.

Table 2: MIFARE Classic command workflow recorded in the repository.

Command	Function
hf mf chk --dump	Test the four explicitly listed candidate keys and save discovered keys.
hf mf hardnested	Use the recorded source block/key type to recover the target Block 4 Key A.
hf mf dump	Read a MIFARE Classic 1K image using a key file and save it under the selected name.
hf mf rdbl	Attempt an authenticated read of one selected block.
hf mf eload	Upload a BIN, EML, or JSON dump to Proxmark3 emulator memory.
hf mf sim --1k	Present emulator memory as a MIFARE Classic 1K card.
hf mf cload	Copy a binary image to a Gen1a Magic Card.
hf mf restore	Restore a MIFARE Classic 1K image with the --1k option, using the authenticated-write path identified in the instruction file for Gen2 cards.
hf mf wipe	Invoke the Magic-Card wipe operation.

4.2.1 Candidate-Key Testing. `hf mf chk --dump` tests the four candidate keys written explicitly in the instruction file. The `--dump` option stores discovered keys for later commands. This stage should be distinguished from cryptanalytic recovery: a successful check means that a supplied value was already a valid key. Nevertheless, one valid sector key can serve as the known source required by the `hardnested` command.

The repository file named `my_keys.dic.json` is not a plain-text dictionary despite the `dic` component in its name. Its `FileType` field identifies it as an `mfc v2` card image, and it contains card metadata, sector keys, and block data.

4.2.2 Hardnested Recovery. The `hardnested` command separates the known source parameters from the unknown target parameters. In the recorded command, `--blk 24`, `-a`, and `-k` select the source block, Key A, and its known value. The options `--tblk 4` and `--ta` select target Block 4 and target Key A. This distinction is essential because the block number determines the sector and the key-type flag determines which half of the trailer credential is being recovered.

The Proxmark3 logs contain multiple `hardnested` invocations with different source and target blocks. They also contain `hf mf autopwn`, which combines candidate-key checks, available recovery strategies, key-file generation, emulator transfer, and dump generation. Because `autopwn` is present in the logs rather than the instruction file, it is treated as additional recorded evidence rather than a step written in that file.

4.2.3 Memory Acquisition. `hf mf dump` uses recovered keys to authenticate and read the card blocks. The retained logs show dump operations producing a 1024-byte binary file and a structured JSON file. Three tracked image pairs are present: `my_keys.dic`, `ID_lyl`, and `ID_ypz`. Each JSON image declares `mfc v2`, contains 64 block

entries and 16 sector-key entries, and has a corresponding 1024-byte binary image.

The binary file is the byte-oriented image used by restoration commands, whereas JSON preserves structured metadata and is directly accepted by the emulator-loading command. These artifacts contain decoded card memory rather than time-domain RF samples; their role is protocol-level reproduction, not physical-layer model training.

4.2.4 Emulation and Persistent Writing. `hf mf eload` transfers a saved image into Proxmark3 emulator memory. The simulation command then presents that memory through the high-frequency interface as a MIFARE Classic 1K card. This path is volatile: it uses the Proxmark3 as the card-side device and does not alter a separate physical card.

For persistent copying, the instruction file assigns `hf mf cload` to Gen1a cards and `hf mf restore --1k` to Gen2 cards. The distinction matters because Gen1a cards expose a special write path, while the `restore` command follows authenticated block writing and requires suitable current keys and access conditions.

4.3 Recorded Proxmark3 Results

The retained client logs provide the following directly observable results:

- `log_20260721034814.txt` records `hf mf eload`, an upload of 64 blocks and 1024 bytes, `Done!`, and a subsequent `hf mf sim --1k` command.
- `log_20260722031003.txt` records a dump that saved a 1024-byte binary image and a JSON image.
- The same log records `hf mf cload` loading a 1024-byte image, copying it to a Gen1a MIFARE Classic 1K card, loading 64 blocks, and returning `Done!`.
- A recorded `hf mf autopwn` run generated binary and JSON dumps and reported an execution time of seven seconds.

These observations establish command completion and artifact generation. A `Done!` response from a card-writing command indicates that the Proxmark3 client completed that operation; it is not, by itself, a measurement of an access-control decision.

4.4 Theoretical End-to-End Validation

An end-to-end validation can separate three questions. First, *key completeness* can be assessed by checking whether the required Key A/Key B positions are populated and whether protected blocks can be read. Second, *logical reproduction* can be assessed by acquiring a fresh image from the emulator or destination card and comparing its UID, data blocks, and sector trailers with the source. Third, *application behavior* can be assessed by presenting the genuine card, emulator, persistent reproduction, and an unrelated control to the same reader configuration and recording each smart-lock decision stage.

For the implemented smart-lock format, the most relevant comparison covers the presented UID, Sector 1 Key A, and Blocks 4–6. A UID-only reproduction cannot demonstrate equivalence because the lock also performs sector authentication and reads the whitelisted credential and dates. Conversely, a successful Proxmark3

write cannot demonstrate application acceptance without observing the reader-side decision. Separating these layers prevents key recovery, memory copying, and lock acceptance from being reported as if they were the same result.

4.5 Theoretical Limitations

The workflow is specific to MIFARE Classic and Crypto-1. It should not be transferred directly to other product families that use different authentication protocols and cryptographic designs. Recovery behavior may also differ between MIFARE Classic revisions because nonce behavior influences which recovery strategy is applicable.

Protocol-level equality does not imply physical-layer equality. A Proxmark3 emulator and a rewritable card can reproduce logical identifiers and memory while using different analog front ends, clock sources, load-modulation circuits, and antennas. Such differences provide the theoretical basis for examining physical-layer fingerprints in the following section.

5 Fingerprinting Defense

6 Discussion and Future Work

7 Conclusion

This project successfully demonstrates the severe security risks associated with static credential exposure over the NFC interface and provides an academic proof-of-concept for dynamic physical-layer defense.

References

- [1] RfidResearchGroup. (2026). *The Proxmark3 Open-Source Firmware Ecosystem*. GitHub Repository.
- [2] ISO/IEC 14443. *Identification cards – Contactless integrated circuit cards – Proximity cards*.
- [3] K. Finkenzeller. *RFID Handbook: Fundamentals and Applications in Contactless Smart Cards, Radio Frequency Identification and Near-Field Communication*. 3rd ed., Wiley, 2010.
- [4] T. Kasper, D. Oswald, and C. Paar. “All You Can Eat or How to Break an NFC MIFARE Classic Card.” In *Black Hat USA*, 2012.
- [5] E. Haselsteiner and K. Breitfuß. “Security in Near Field Communication (NFC): Strengths and Weaknesses.” In *Workshop on RFID Security (RFIDSec)*, 2006.
- [6] F. D. Garcia, G. de Koning Gans, R. Muijers, P. van Rossum, R. Verdonchot, R. Wiegerinck, and J. Horizons. “Dismantling MIFARE Classic.” In *ESORICS*, 2008.